AIMScribe v3 - Security and Compliance Review

How patient data is protected at every boundary, what a full security audit of the code found and how each finding was closed, and how the system measures against HIPAA, GDPR and HL7 FHIR. Third edition, 20 October 2026: after CMED agreed to per-hospital tokens and FHIR, and after a second, six-reviewer quality round (Part 2B).

The answer to the reviewer, point by point

Concern	Answer
1. The APIs are not live	**True today, and the next step.** The server runs on AIMS LAB's own test system and has not yet been given a public address, so CMED could not call it. Everything needed is ready: the deployment manual (DigitalOcean, from account creation to the first recording), the hardened gateway, and a test tool CMED runs against it. What it needs is the hosting account and a domain name; then CMED receives a staging address, a client id per hospital and the test command (Part 4).
2. Security and authentication vulnerabilities in the flow	**Audited twice, end to end.** A first audit found 31 issues (Part 2); a second round of six independent reviews, including one reading our documents as CMED would, found about 60 more, among them five critical data-safety bugs (Part 2B). All are fixed in the code and tested, except the open items listed in Part 4.3. CMED no longer uses one shared key: each hospital is its own client with its own key pair and five-minute tokens; every request a clinic PC makes is signed with that PC's key. **Recorder fixes reach a clinic only with installer 3.5.0**, which is waiting for a code-signing certificate.
3. HIPAA / GDPR / HL7 FHIR	**FHIR R4 is implemented** for the server-to-server messages (API 2 and API 3b), with HL7's SMART Backend Services authentication, and CMED has agreed to send it. HIPAA's technical safeguards and GDPR's principles are met in the code, except named-person dashboard accounts (Part 3). The organisational documents - risk sign-off, DPIA, processor agreements, breach procedure - are still to be written by the project's owner.
4. Parts of the FRS and API documentation need discussion	**Agreed; the integration document is rewritten** around the token method and FHIR (new Part H, with every element and code). Eight decisions are listed in Part 4 for the meeting with CMED, each with a proposed answer.

Integrity, not only secrecy

Each clip and each event of a recording is hashed and signed into a chain by the PC's own key; the server verifies the chain before it accepts a recording, and the archive proves every file against those hashes. The audit log and the clinical access log are append-only: database triggers refuse any change or delete. **Correction to the first edition**, which said the triggers stop "anyone": that was not true while the API logged in as the tables' owner, because an owner can switch a trigger off. The API now logs in as `aims_api`, which cannot; tested by trying it ("must be owner").

PART 1

Every boundary, and what protects it

Who talks to whom, how each side proves who it is, and how the data is protected on the wire and at rest.

Boundary	Proving who is talking	On the wire	At rest
CMED doctor page → recorder (Channel A: API 1, 3a), same PC	Loopback only (127.0.0.1); refused unless the browser's Origin is CMED's exact page; at most 16 connections and 10 messages a second each. **A message can start, stop or mark, but never erase**: only the doctor's on-screen control can record a refusal	Does not leave the PC	-
Recorder → AIMS LAB server	Per-PC key created inside the PC's TPM chip (P-256): usable on that PC, never copyable off it (3.6; earlier PCs keep a DPAPI-locked Ed25519 key until re-enrolled). Joins with a single-use enrolment token, or from 3.7 with none: it proves it holds a TPM key and is pending - uploading at most 500 MB, none of it kept unless CMED confirms it - until CMED's server confirms two of its recordings. Every recording needs a server-signed grant, 60 s life, single use - remembered across restarts. Every request is signed with the PC's key (single-use nonce, 5-minute window). A PC cannot open another PC's recording	TLS (HTTPS only, HSTS)	AES-256-GCM spool, partial audio and journal; deleted only on a server-signed receipt
CMED's server → AIMS LAB server (Channel B: API 2, 3b)	**One client per hospital** (SMART Backend Services): CMED signs a 5-minute assertion with that hospital's private key (ES384); we hold only the public key. It buys a 5-minute token bound to that hospital. Each assertion works once. Optional address allow-list per hospital. Revocable per hospital, effective at once	TLS, HSTS; tokens removed from access logs; FHIR R4	Clinical database; tokens kept only as SHA-256
Server → databases	**The API logs in as** `aims_api`: it may read and write rows, may only add to the audit log, and cannot alter a table or switch a trigger off. The owner role cannot log in; it exists for migrations	Private Docker network, no published ports	See O1
Each service → its secrets	Each container receives only the variables it reads. The API holds no cloud-copy key, no backup key and no database superuser password	-	-
Cloud archive copy (R2)	Bucket-scoped token; key never leaves AIMS LAB	TLS	AES-256-GCM in chunks; every chunk sealed to its recording, part and kind, so a copy cannot be passed off as another
Nightly database backup	Its own bucket and token; refuses to run without its key	TLS	Encrypted as it is written (no plaintext ever on disk), owner-only, with a SHA-256 checked before any restore
People → dashboard and admin	Admin key; **reachable only from AIMS LAB's addresses** (gateway allow-list) or an SSH tunnel; repeated wrong keys lock the address out	TLS; strict Content-Security-Policy	Shows no patient names

PART 2

What the audit found, and what was done

31 findings, ranked. FIXED means changed and tested; ACCEPTED means a stated, deliberate risk; OPEN means work outside the code.

Severity	Finding	State	What was done
CRITICAL	The old v1 API answered the internet without any login: anyone with a recording's ID could read its transcript and prescription, relabel it, or create upload links	**FIXED**	Removed from the server; the gateway also refuses `/api/v1`. Checked live: 404
CRITICAL	One CMED key spoke for every hospital, and the hospital was taken from the message: one leak let anyone write for, and list visits of, all hospitals	**FIXED**	Per-hospital clients and tokens; a message for another hospital is refused (403) and raises a critical alert; visits are listed only for the credential's hospitals. The interim key must name its hospitals, expires in 90 days, and is off on a real server
HIGH	A program on the doctor's PC posing as CMED's page could send "patient refused" and erase a live consultation	**FIXED**	The socket can no longer erase; a refusal comes only from the on-screen control
HIGH	Environment variables overrode the recorder's protected settings (switch off permission checks, redirect uploads)	**FIXED**	The installed program ignores them and refuses to record with an unsafe setting
HIGH	The API logged in as the tables' owner, so a break-in could disable the audit log's protection	**FIXED**	Least-privilege login `aims_api`; the server warns at start if it is ever the owner
HIGH	Every secret was handed to the internet-facing container	**FIXED**	Per-service variable lists
HIGH	The clinical JSON (with the patient's name) stayed on the server's disk after its audio was released	**FIXED**	Overwritten and deleted with the audio; archive files owner-only
HIGH	No rate limits; no alert on repeated wrong credentials	**FIXED**	Per-address and per-token limits; 10 wrong credentials lock an address out for 15 minutes and raise one alert
HIGH	Server and archive worker had no route to the cloud bucket on the production layout (found by the audit, a functional bug)	**FIXED**	Separate outbound-only network
HIGH	Upload links on the production layout would have named localhost, so no PC could upload (found by the audit)	**FIXED**	The public storage address is passed correctly
MEDIUM	Worker and admin routes reachable from the internet	**FIXED**	Worker routes refused at the gateway; admin and dashboard only from AIMS LAB's addresses
MEDIUM	The API's /docs listed all 52 routes publicly	**FIXED**	Off
MEDIUM	A PC that knew another PC's recording ID could attach to it	**FIXED**	Refused (409) with a critical alert
MEDIUM	Any Windows user could replace the server's public keys in ProgramData	**FIXED**	Keys moved under Program Files; the data folder locked down
MEDIUM	The installer's local key came from a weak random function	**FIXED**	Windows' cryptographic generator; old keys replaced once on upgrade
MEDIUM	The local test system listened on the whole network	**FIXED**	Loopback by default; network mode only on request

MEDIUM	Backups readable by any server user if the key was unset; no tamper check	**FIXED**	Refuses without the key; owner-only; SHA-256 checked before restore
MEDIUM	One shared admin key, no named people	**OPEN**	Mitigated by the address allow-list and lockout; named per-person keys are the next step (Part 4)
LOW	CMED keys never expired by default	**FIXED**	90 days for the interim key; tokens live 5 minutes; hospital clients a year
LOW	Error replies could carry internal details	**FIXED**	Generic message and a reference; details only in the server log
LOW	Patient IDs in plain text in the recorder's journal	**FIXED**	Encrypted with the spool key, bound to the session
LOW	A recording permission could be replayed across a recorder restart	**FIXED**	Used permissions remembered on disk for an hour
LOW	The startup task ran with more rights than needed	**FIXED**	Least privilege
LOW	A cloud copy did not prove which recording it belonged to	**FIXED**	Bound to session, part and kind; old copies still restore
LOW	The enrolment-token sheets were readable by any server user	**FIXED**	Owner-only files and folder
LOW	Default passwords left in the old development files	**FIXED**	Removed
LOW	Gaps in the GitHub ignore list (local manual, keys)	**FIXED**	Ignored; private keys live only in ignored folders
HIGH	Any program on a PC could unwrap its identity key (DPAPI machine scope) and act as that PC from anywhere	**FIXED**	3.6 creates the key inside the PC's TPM at install: programs may use it on that PC, none can export or delete it (tested on real hardware). Earlier PCs keep their key until re-enrolled
ACCEPTED	Any user of the PC can delete unsent audio from the spool	**ACCEPTED**	Needed for the same reason; a deletion breaks the signed chain and is reported
ACCEPTED	The enrolment token is readable on the PC until the first enrolment uses it	**ACCEPTED**	Single use, used within minutes of installation, and from 3.6 it registers only a key the PC proves it holds - inside its own TPM
HIGH	Recordings CMED never confirmed were indistinguishable from confirmed ones; any bytes were accepted as audio	**FIXED**	Every recording is stored and its JSON is marked cmed_confirmed true/false, with the reason, kept current; only confirmed ones count as the dataset. Every piece must be WAV in the declared format; two PCs claiming one consultation are both held
OPEN	The server's disk	**OPEN**	The deployment manual now puts /srv/aimscribe on a DigitalOcean volume (encrypted at rest by the provider); not yet applied, as the server is not yet deployed

In the code, or on the clinic PCs? Every recorder item above (socket erase, environment override, key location, secure random key, journal encryption, replay memory, task privilege) is in recorder 3.5.0. The clinic PCs run 3.4.0 until the signed 3.5.0 installer is rolled out; server items take effect when the server is deployed.

PART 2B

The second round: six reviews, and what they changed

Server, recorder, CMED interface, API standards, installation, and our documents read the way CMED reads them.

Severity	Finding	State	What was done
CRITICAL	A clip's signed chain record was never checked against the clip it described, so signed records could be replayed over other audio	**FIXED**	Every entry must name its clip's number, fingerprint and length, follow the head exactly, and match its endpoint; the genesis is bound to its PC and recording
CRITICAL	With the disk full, clips waiting to be written went into the next patient's recording, or were dropped	**FIXED**	Each recording has its own clip writer; a failed write keeps the clip
CRITICAL	Clips accepted after a recording closed got a receipt (so the PC deleted them) but were not in the archive, and the bucket copy was deleted	**FIXED**	Closed recordings refuse clips; the archive reports exactly the clips it joined, and only those are receipted, marked and deleted
CRITICAL	A refusal racing with an upload or the archive could leave refused audio stored and copied to the cloud; an erase left the archive file	**FIXED**	One writer per recording at a time (row lock); a refusal now removes the archive files and cloud copies too
CRITICAL	Erasing a consultation needed only the PC's bearer token, at any age	**FIXED**	Refusals are signed by the PC's key and accepted for 7 days; unsigned (old recorders) for 2 hours only, with an alert; older ones by an administrator
HIGH	The lockout was per address: one stale PC locked out its clinic, one revoked hospital all of CMED	**FIXED**	Per credential, shared across server processes through Redis; allow-listed addresses never locked; clock skew never counted
HIGH	About 30 malformed FHIR shapes, NaN or a lone surrogate gave 500 (CMED would retry forever)	**FIXED**	Every one answered 400 with the element named; each is a regression test
HIGH	A patient with several identifiers was refused; a time written as Z or with milliseconds became another visit	**FIXED**	Identifier selection order; one canonical spelling of the start time
HIGH	Our example FHIR was not valid R4 (missing subject); scope names were not SMART; 202 where FHIR expects 200	**FIXED**	subject on every clinical resource, MessageDefinitions, SMART v2 scopes (old names accepted), 200
HIGH	A failed Resume left a recording stuck paused; a cancelled Windows shutdown stopped recording; one failed upload blocked all uploads for 13 minutes	**FIXED**	Each fixed with a regression test
HIGH	Two Windows users signed in: the second user's patients recorded by the first user's agent, unable to refuse	**FIXED**	Connections from another Windows session are refused
HIGH	The installer is unsigned and changed Windows policy; the agent restarted every minute and ran hidden PowerShell - why clinics had to switch security off	**PARTLY**	Signing pipeline built (fails the build if anything is unsigned); policy moved to a separate admin script; no hidden PowerShell; silent install. **Needs a code-signing certificate**
MEDIUM	No request ids; four error formats; no machine-readable contract; /health 200 when degraded	**FIXED**	X-Request-ID everywhere, RFC 9457 problem+json, openapi/channel-b.json, /health/live and /health/ready
MEDIUM	Device tokens were bearer secrets; the recorder trusted any root, including antivirus HTTPS inspection	**FIXED**	Every device request signed with the PC's own key (single-use nonce, 5-minute window); optional key pinning; interception reported

MEDIUM	Client expiry with no renewal or warning; revoking a key left its tokens alive	**FIXED**	Renew endpoint, 30-day alert, key revocation ends its tokens
MEDIUM	Patient ids are visible in cloud object names (encrypted contents, plain names)	**OPEN**	To replace with a keyed hash; stated in the server document
LOW	Stale versions, dates and numbers across the documents; the server document still described the shared key	**FIXED**	All documents regenerated from the code

Tests after both rounds: server 441 (on a real PostgreSQL), recorder 385, archive 155, deployment 87, tools 39. Live on the lab system: the CMED test (token + FHIR) passes 11 of 11, the browser channel 24 of 24 with the installed 3.4.0 recorder, and /health/ready answers 200.

PART 3

Measured against HIPAA, GDPR and HL7 FHIR

Benchmarks: which safeguards are met, partly met, or still to do.

Which law applies. HIPAA binds US covered entities and GDPR applies to data about people in the EU; neither governs a clinic in Bangladesh directly. They are used here as the clearest published standards for health data. The binding requirements are Bangladeshi law and the study's ethics approval: confirm both with UIU's ethics board and legal office.

3.1 · HIPAA Security Rule, technical safeguards (45 CFR 164.312)

Safeguard	State	In AIMScribe
Access control - unique user ID	**PARTLY**	Every PC and every hospital is identified; people on the dashboard still share one key (Part 4.3, item 2)
Access control - emergency access, automatic logoff	**MET**	The dashboard key lives only in that tab; closing it ends access
Access control - encryption	**PARTLY**	PC, cloud copies and backups encrypted; the server's data volume is in the deployment manual but not yet applied
Audit controls	**MET**	Append-only audit log and clinical access log, protected from the API's own login; every read of clinical data recorded
Integrity	**MET**	Signed hash chain per recording; hashes verified at archive and copy; signed purge receipts; copies sealed to their recording
Person or entity authentication	**PARTLY**	Machines: per-PC keys and signed grants. Hospitals: per-hospital key pairs and tokens. People: shared key
Transmission security	**MET**	TLS on every network hop; HSTS

Administrative and physical (HIPAA 164.308/310)	State	Note
Risk analysis	**PARTLY**	This document is its technical part; it needs a named owner's sign-off
Contingency plan: backup, recovery	**MET**	Nightly encrypted backups, off-site copy, restore drill in the manual
Business associate agreements	**TO DO (organisation)**	With the hosting and storage providers (both offer them on request)
Workforce training, breach procedure	**TO DO (organisation)**	To write: who is told, how fast, what is recorded

3.2 · GDPR principles (Article 5) and data-subject rights

Principle or right	State	In AIMScribe
Lawfulness, consent	**MET**	Consent at reception; a patient's refusal erases the recording and everything CMED sent for that visit
Purpose limitation	**MET**	Research dataset only
Data minimisation	**MET**	No names on the dashboard; a hospital's credential sees only its own visits
Accuracy	**MET**	Corrections kept as new versions; one hospital cannot rewrite another's prescription
Storage limitation	**PARTLY**	Local and backup retention set; the archive's long-term period must be decided
Integrity and confidentiality	**MET**	Part 1 and Part 2
Accountability	**MET**	Append-only audit of who did what, including which hospital client sent each message
Right to erasure (Art. 17)	**MET**	The refusal path erases audio, clinical data and copies
Right of access and portability (Art. 15, 20)	**PARTLY**	Clinical data arrives in FHIR; a per-patient FHIR export is the remaining step
DPIA (Art. 35); processor agreements; 72-hour breach notice	**TO DO (organisation)**	To write before go-live

3.3 · HL7 FHIR R4 - implemented

API 2 and API 3b are FHIR R4 messages: a `Bundle` of type `message` posted to `/fhir/r4/$process-message`. The visits held for a patient are an `Encounter` search. The server publishes its `CapabilityStatement` at `/fhir/r4/metadata` and its token address at `/.well-known/smart-configuration`, so a standard FHIR client configures itself. Each message is read into the same content the earlier JSON carried and goes through the same rules; a reference client in Python and one in TypeScript produce messages the server reads back field for field.

What CMED sends	FHIR R4
The visit (patient, doctor, clinic, start time)	Encounter, with Patient, Practitioner, Organization by identifier
Demographics	Patient (name, gender, birthDate, telecom, address)
Paramedic measurements	Observation, LOINC: weight 29463-7, height 8302-2, blood pressure 85354-9, pulse 8867-4, temperature 8310-5, SpO2 59408-5, age 30525-0
Prescription items	MedicationRequest (dosage, timing, duration)
Diagnoses / investigations	Condition / ServiceRequest
Advice, follow-up, notes	CarePlan
The previous visit	A second Encounter, with its own resources
Our reply	A response message: MessageHeader.response, OperationOutcome, Parameters
Authentication	SMART Backend Services: private_key_jwt, client_credentials, system scopes

PART 4

To go live, and to agree with CMED

What is left, in order, and the decisions for the meeting.

4.1 · Making the APIs live (concern 1)

#	Step	Who
1	Hosting account and a domain name (e.g. aimscribe.<uiu domain>)	AIMS LAB
2	Deploy with the manual; the gateway refuses everything but the public routes	AIMS LAB
3	CMED makes one key pair per hospital and sends the public keys and their server addresses	CMED
4	AIMS LAB registers each hospital and returns its client id and key id	AIMS LAB
5	CMED runs `tools/channel_b_test.py --client-id ...` against staging: 11 of 11 must pass	CMED
6	Production: the same, with the interim static key switched off	both

4.2 · Decisions for the meeting with CMED (concern 4)

Question	Proposed answer
Identifier systems for patient, doctor and hospital	CMED's own URIs, registered per hospital. Ours are only proposed; several identifiers per resource are fine
Plain FHIR R4, or Bangladesh's BD Core profiles	Plain R4 now; BD Core profiles can be declared in meta.profile without changing the content
Which hospitals, and their ids	CMED's list; one client each
CMED's server addresses	For each hospital's allow-list
Signing algorithm	ES384 (RS384 and ES256 also accepted)
When the interim static key is switched off	Before the first real patient
History from another hospital	Fills a gap; never changes that hospital's own prescription
The archive's retention period	To decide with the ethics board

4.3 · Remaining work on our side

#	What	Kind
1	Code-signing certificate, then the signed 3.5.0 installer rolled out to every clinic PC	purchase + rollout
2	Named per-person admin keys, recorded in every audit entry	code
3	Keyed hash instead of the patient id in cloud object names	code
4	Per-patient FHIR export (GDPR Art. 20)	code
5	Encrypted data volume applied on the server; BitLocker on every clinic PC	deployment
6	Signed requests and signed refusals made mandatory once every PC runs 3.5.0	configuration
7	Risk sign-off, DPIA, processor agreements, breach procedure, retention period, ethics confirmation	documents

Nothing in this list blocks CMED from starting: the token method and FHIR are built, documented and tested.